Specify security for SaaS, PaaS, IaaS, and AI workloads



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



Connected Equipment ships every two weeks

Its public API has inconsistent protection

Its customer assistant skipped security review

The ERP agent shares the AI platform

Specify baselines across SaaS, PaaS, and IaaS

The service model changes your operating boundary

Globomantics design example

Customer decisions	IaaS	PaaS	SaaS
Identity, data, access	CUSTOMER	CUSTOMER	CUSTOMER
Application code	CUSTOMER	CUSTOMER[1]	PROVIDER[1]
Guest OS + runtime	CUSTOMER	PROVIDER	PROVIDER
Physical infrastructure	PROVIDER	PROVIDER	PROVIDER

[1] Service-specific configuration still needs customer decisions.

Outsourcing an operating layer leaves customer access decisions in place.

Turn responsibility into a testable baseline

Write the requirement: only the maintenance service reads telemetry

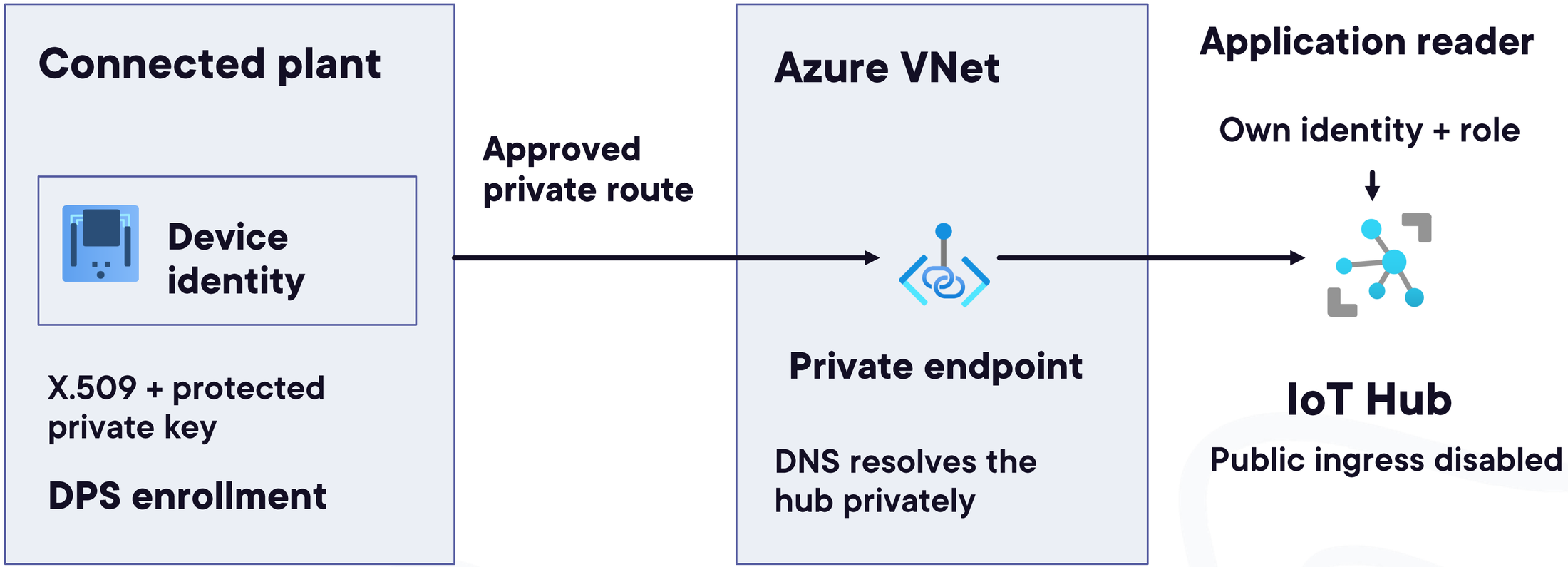
Map it to a service setting and owner with the MCSB v1 baseline

Assess it with Defender for Cloud and Defender for Cloud Apps

Specify requirements for IoT workloads

Telemetry crosses two different trust boundaries

Globomantics design example

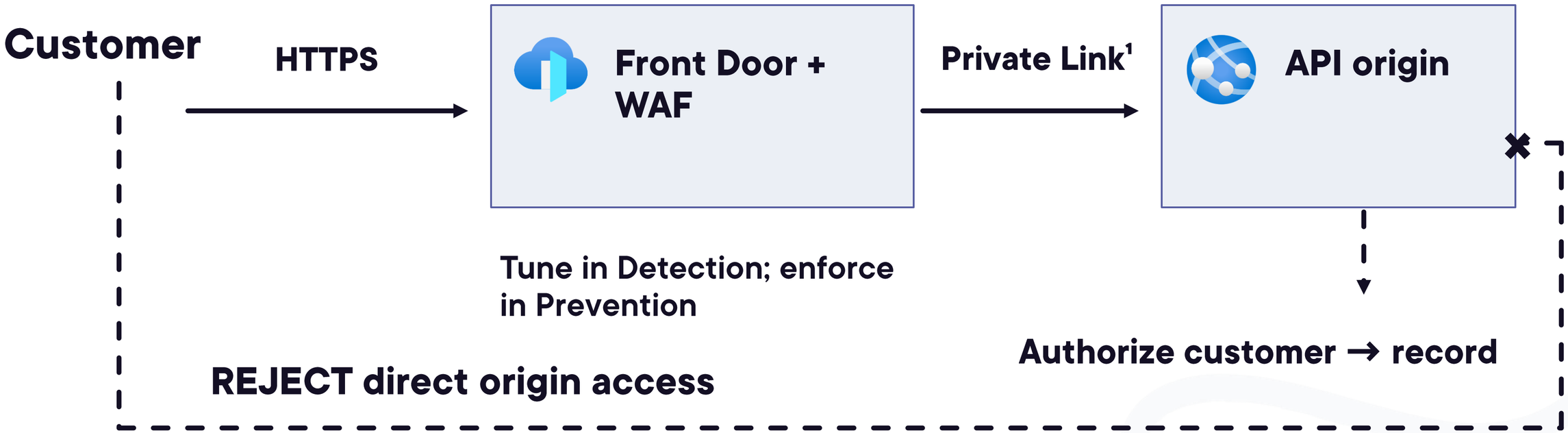


A private endpoint needs reachability; device trust and data access need separate identities.

Specify requirements for web workloads

Every public request must pass the intended WAF

Globomantics design example

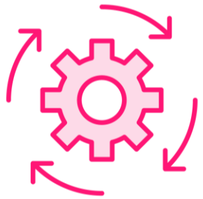


[1] Supported origin and required tier

WAF coverage depends on the path. Customer data access depends on application authorization.

Specify requirements for containers

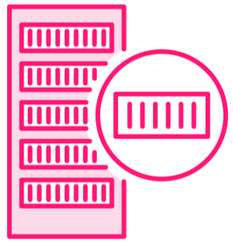
Container checks before deployment



Build from trusted source and a maintained, minimal base image



Scan in the pipeline and stop releases that fail the threshold



Promote the approved digest to a private Azure Container Registry

Repair the source of the next container

Instance patch	vs.	Source repair
Patches one running container		Rebuilds from a fixed base image
Leaves the base image unchanged		Scans the rebuild automatically
Reverts at the next deployment		Promotes a new approved digest
Contains, but doesn't repair		Verifies the deployed digest

Specify requirements for container orchestration

Separate cluster authority from workload traffic

Management API: Entra authentication, RBAC and a private endpoint

Pods: network policy and the Restricted Pod Security Standard

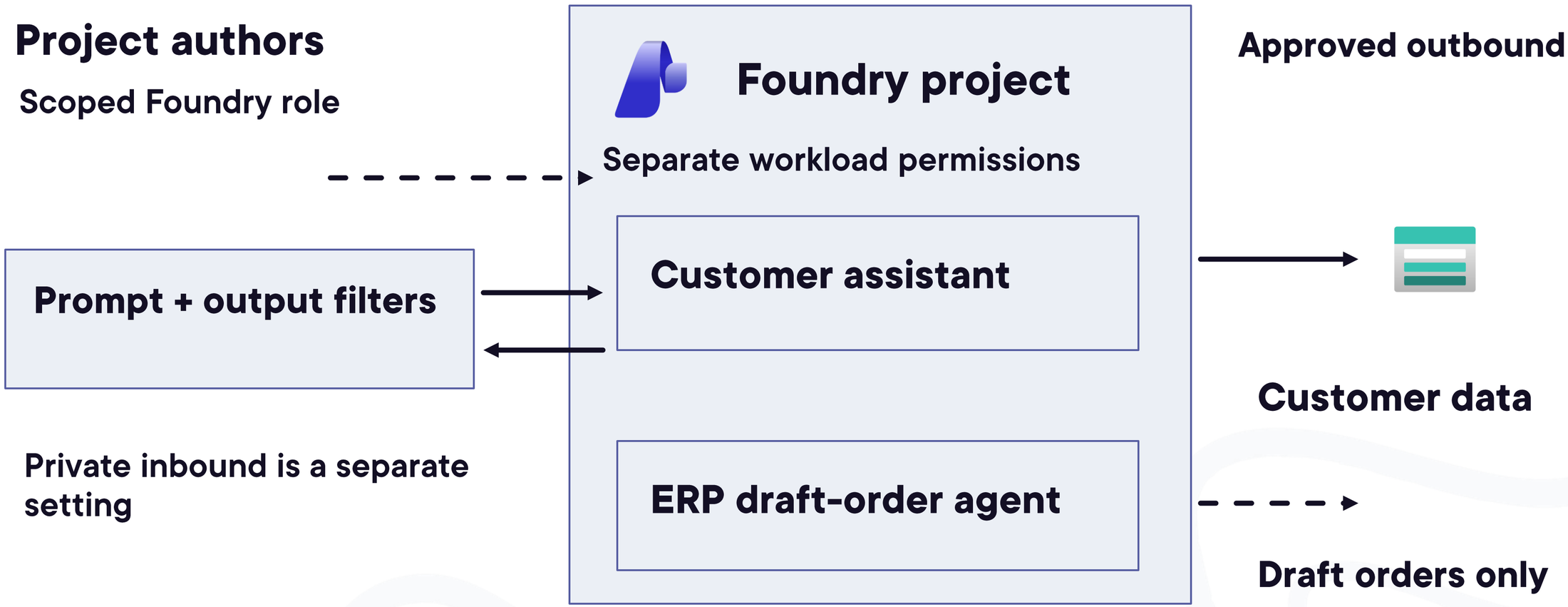
Egress: route cluster traffic through Azure Firewall

Data: workload identity, a scoped role and Key Vault

Evaluate security for AI workloads in Microsoft Foundry

The assistant can reach only approved dependencies

Globomantics design example



AI control family: MCSB v2 preview

Content filtering can't replace limited data access and tool permissions.

Demo: Evaluate a Foundry project against the AI controls

Read the Foundry project's boundary settings, then decide which workload identity keeps too much access

Practice question and key points

Theme: Container security requirements

Question

Every Globomantics release restores a vulnerability that operations patched. Releases must stay automated. What should you recommend?

A. Azure Policy: require the Restricted pod standard

B. Azure WAF: enforce the managed prevention rules

C. Defender for Containers: detect runtime binary drift

D. GitHub Actions: rebuild and gate vulnerability scans

Theme: Container security requirements

Answer: D

Every Globomantics release restores a vulnerability that operations patched. Releases must stay automated. What should you recommend?

A. Azure Policy: require the Restricted pod standard

B. Azure WAF: enforce the managed prevention rules

C. Defender for Containers: detect runtime binary drift

D. GitHub Actions: rebuild and gate vulnerability scans

Checking out with Globomantics



Derive the baseline from customer responsibility

Place controls at the stage that can fix the cause

Evaluate AI access, networking and content separately

Keep the ERP agent limited to draft orders